AI Risk Review

Design prototype. All company context, findings and actions below are illustrative. This page did not inspect a computer or assess a business.

LEADERSHIP BRIEFING · EXAMPLE BUSINESS

AI readiness, at a glance.

A clear view of what is known, what needs a decision, and who should act.

Prepared with AI Risk Review · October 2026 · Report design prototype 1

RECOMMENDED LEADERSHIP FOCUS

Confirm approved use and accountable owners.

This example identifies AI tools on one computer. Work use, data handling and approval are not yet established. Assign owners and request the missing evidence before deciding whether to expand access.

3	2	3
tools observed	connections to clarify	proposed next actions

What the evidence tells us

✓ **Tool presence observed**
ChatGPT, Claude and Codex in sample records.

? **Business purpose unknown**
Confirm which activities use these tools.

? **Approval and oversight unknown**
Request owners, rules and review procedures.

? **Company-wide use unknown**
Other devices and business systems are outside scope.

Scope: one computer, one user.
Completing local checks does not establish company-wide coverage, secure configuration or compliance. No incident or data leak is established by these sample observations.

Three requests for your team

Proposed actions · no owners assigned

1 Set boundaries for work use

Ask Operations to confirm permitted tools, information types and when a person must review AI output.

? Approval not established

▼ Why it matters & supporting detail

Business concern	Without clear rules, people may handle information differently. Inappropriate use has not been established.
Decision needed	Name an accountable owner to confirm existing rules or propose an AI-use policy.
Evidence basis	Tool presence E01; missing business context E05.
Completion evidence	A dated approval decision, permitted-use guide and evidence that relevant people received it.

2 Clarify what assistant connections can access

Ask IT to document the purpose, owner and actual permissions of the two configured connections.

✓ Configuration observed

▼ Why it matters & supporting detail

Business concern	Connections can extend an assistant's access. A configuration entry alone does not prove that a connection is active or unsafe.
Decision needed	Approve, restrict or remove connections after an owner verifies their purpose and permissions.
Evidence basis	Sample remote and local configuration records E02–E03.
Completion evidence	An owner-reviewed register showing purpose, permissions, approval and review date.

3 Establish the wider business picture

Ask team leads to reconcile browser tools, AI in business systems and other devices with an AI-use register.

? Coverage gap

▼ Why it matters & supporting detail

Business concern	One computer cannot establish which AI activities exist across an organization.
Decision needed	Assign an executive sponsor and define the teams, systems and activities included in the next review.
Evidence basis	Collection boundary E06.
Completion evidence	A reconciled use register containing purpose, owner, information types, approval and review date.

From findings to ownership

Action register · illustrative

Action	Proposed owner	Suggested timing	What closes it
Confirm permitted work use Owner needed	Operations CEO to assign	Start this week	Approved rules and a documented data-handling decision.
Review two connections Owner needed	IT / security CEO to assign	Before expanding connection access	Verified purpose, permissions, owner and approval.
Reconcile wider AI use Scope needed	Team leads Executive sponsor coordinates	Next review cycle	AI-use register reconciled against agreed scope.

Timing is a proposed management sequence, not a legal deadline. Owners must estimate effort and cost. This prototype assigns no tasks and sends no messages.

Where AI fits in the business

Illustrative workflow. The actual information flow still needs confirmation.

1. Information in

? Not established

Data types, sensitivity and destinations need confirmation.

→

2. AI tools & connections

✓ Presence observed

Three tool identities and two connection configurations.

→

3. Output & human review

? Not established

Who checks outputs and which decisions depend on them?

Tool	Business purpose	Approval / owner	Evidence
ChatGPT	Not established	Confirm with business owner	Sample presence record
Claude	Not established	Confirm with business owner	Sample package record
Codex	Not established	Confirm with business owner	Sample presence & configuration

Which requirements matter?

? Applicability unresolved

First confirm activities, affected jurisdictions, organizational roles and contracts. The report should then explain why a requirement may apply and which evidence supports the conclusion.

Risk-management baseline	NIST AI RMF can organize inventory, accountability and oversight work. A mapping is a reference aid; it does not establish compliance.
U.S. laws and policies	Context is needed before selecting applicable obligations. This prototype makes no legal applicability or current-law determination.

The evidence behind the brief

Sample appendix · no live collection

Observed means present in a sample record. **Not established** means insufficient evidence. **Candidate** means a possible document match awaiting review.

E01

AI tool presence · observed in sample

Illustrative package and process records identify ChatGPT, Claude and Codex. Presence does not establish work use, approval, active accounts or the authenticity of every matching process.

E02

Remote connection declaration · observed in sample

A sample configuration declares one HTTPS connection. Its identity, activity and effective permissions are unverified. An absent authentication field does not establish an unauthenticated service.

E03

Local connection declaration · observed in sample

A sample configuration declares one local command connection. Declaration does not prove execution. An undeclared tool list does not mean the connection has no capabilities.

E04

Local listeners · observed in sample

Loopback bindings are illustrative local observations. They do not establish authentication quality, secure configuration or every possible access path.

E05

Business context and approval · not established

No verified work purposes, approved-use decision or oversight procedures are supplied in this example. Missing evidence does not prove that these controls do not exist.

E06

Review boundary · one computer and user

Other employees, devices, browser accounts and AI embedded in business systems are outside this example's scope. Local completion cannot be interpreted as organization-wide coverage.

▼ How a document candidate would appear

Illustrative excerpt · not an actual company policy

> Only approved AI tools may process client information.

Example AI-use policy · paragraph 4 · Candidate C01

This authored sample demonstrates citation layout. A real reviewer must verify context, approval and implementation. A matching sentence never automatically passes a control.

Methods, mappings & limits

▼ Collection methods and coverage limits

This prototype collected nothing. In a real report, record enabled and skipped collectors, errors, collection time and scope. Read-only local discovery may combine package, process, listener and opt-in configuration observations; it cannot verify all business activities.

▼ Example crosswalk: how actions relate to NIST AI RMF

Authored, partial reference mapping. It is not a complete framework assessment or certification.

Work	Reference	Evidence still needed
Reconcile AI-use inventory	GOVERN 1.6	Business scope and maintained register.
Assign accountability	GOVERN 2.1	Named roles and approved responsibilities.
Define human oversight	GOVERN 3.2	Review procedures and evidence of operation.

▼ Sharing and privacy

Real appendices may contain sensitive local or business details. Review the actual export before sharing. This illustrative page contains no collected customer records, sends no messages and makes no external network requests.
